

Security+ 1.4 · Encrypting Data

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 1.4 — Encrypting Data (9:48)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Dado em 3 ESTADOS: AT REST (parado — BitLocker, TDE no banco), IN TRANSIT (viajando — TLS/VPN), IN USE (sendo processado — confidential computing, enclaves CPU). Block cipher (AES — cifra chunks de 128 bits) vs Stream cipher (byte a byte, rápido).

Highlights que a prova cobra

- At rest = disco; In transit = rede (TLS); In use = memória (mais difícil)
- AES block cipher cifra em blocos de 128 bits
- Stream cipher: ChaCha20 — bom pra celular, sem hardware AES

Dicas de prova & Cenários Típicos

- Na prova: 'data stored in the database' = at rest; 'during network transfer' = in transit
- Pergunta de 'which provides protection for data in USE' = confidential computing

Cenário clássico de exame: Cenário: 'empresa precisa proteger o dado que está SENDO processado na memória' → confidential computing / enclaves (in use).

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 1.4 — Encrypting Data)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Proteger dados 'em repouso' (at rest) significa criptografar:

- A) O tráfego na rede
- B) Os dados gravados no storage/disco
- C) A senha do usuário
- D) O código-fonte

2. Em criptografia at-rest, onde os dados estão protegidos?

- A) Durante a transmissão pela rede
- B) Quando armazenados em disco/databases
- C) Em memória durante processamento
- D) Em backups remotos

3. TLS/SSL são protocolos usados para proteger dados:

- A)** At-rest
- B)** In-transit
- C)** Em uso
- D)** Em backup

4. Uma característica de HASH (diferente de criptografia) é que ele:

- A)** Pode ser revertido com a chave
- B)** É de mão única (não reversível)
- C)** Sempre encurta o texto pela metade
- D)** Precisa de par de chaves

5. Cenário corporativo (Encrypting Data): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'At rest = disco; In transit = rede (TLS); In use = memória (mais difícil)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: At rest = disco; In transit = rede (TLS); In use = memória (mais difícil)...

6. Cenário corporativo (Encrypting Data): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'AES block cipher cifra em blocos de 128 bits'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: AES block cipher cifra em blocos de 128 bits...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Encrypting Data): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Stream cipher: ChaCha20 — bom pra celular, sem hardware AES'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Stream cipher: ChaCha20 — bom pra celular, sem hardware AES...

8. Cenário corporativo (Encrypting Data): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Na prova: 'data stored in the database' = at rest; 'during network transfer' = in transit'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Na prova: 'data stored in the database' = at rest; 'during network transfer'...

9. Cenário corporativo (Encrypting Data): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Pergunta de 'which provides protection for data in USE' = confidential computing'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Pergunta de 'which provides protection for data in USE' = confidential comp...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Encrypting Data): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'empresa precisa proteger o dado que está SENDO processado na memória' → confidential computing / enclaves (in use)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Cenário: 'empresa precisa proteger o dado que está SENDO processado na memó...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — Os dados gravados no storage/disco.

✓ **Por que está certa:** Proteger dados 'em repouso' (at rest) significa criptografar os dados armazenados em disco, storage, bancos de dados, backups ou qualquer meio de persistência. A criptografia em repouso garante que, mesmo que o meio físico seja roubado ou acessado indevidamente, os dados permaneçam ilegíveis sem a chave de descryptografia. No CompTIA Security+ SY0-701, esse conceito é abordado como parte da proteção de dados em diferentes estados: em repouso (at rest), em trânsito (in transit) e em uso (in use). A resposta correta refere-se especificamente aos dados gravados no storage/disco, que é a definição exata de 'at rest'.

✗ **Por que as outras estão erradas:**

- *O tráfego na rede:* Criptografar o tráfego na rede refere-se à proteção de dados 'em trânsito' (in transit), utilizando protocolos como TLS, IPsec ou SSH. Isso protege a comunicação entre sistemas, mas não os dados armazenados. A questão pergunta sobre dados 'em repouso', que é um estado distinto. Portanto, essa alternativa descreve um conceito diferente e não responde ao enunciado.
- *A senha do usuário:* Criptografar a senha do usuário é uma prática de proteção de credenciais, geralmente realizada por meio de funções de hash (como bcrypt, Argon2) e não de criptografia reversível. Além disso, a senha é apenas um tipo específico de dado, não abrangendo o conceito amplo de dados 'em repouso'. A proteção de senhas é um subconjunto da segurança de dados, mas não define o que significa proteger dados at rest.
- *O código-fonte:* O código-fonte é um tipo de dado que pode estar em repouso, em trânsito ou em uso. Criptografá-lo seria uma aplicação específica da proteção em repouso, mas não é a definição geral do termo. A alternativa restringe indevidamente o conceito a um único tipo de dado, enquanto a questão busca a definição ampla e correta de 'dados em repouso', que abrange qualquer dado armazenado em disco.

2) B — Quando armazenados em disco/databases.

✓ **Por que está certa:** A criptografia at-rest (em repouso) protege dados quando eles não estão em movimento, ou seja, quando residem em mídias de armazenamento persistente, como discos rígidos (HDDs), unidades de estado sólido (SSDs), fitas magnéticas, volumes de armazenamento em nuvem (ex.: Amazon EBS, S3) e arquivos de banco de dados. O objetivo é garantir confidencialidade e integridade caso o meio físico seja acessado indevidamente, roubado ou descartado incorretamente. A criptografia at-rest pode ser aplicada em nível de disco completo (FDE), de volume, de arquivo ou de banco de dados, e é um controle essencial para conformidade com regulamentos como LGPD, GDPR, HIPAA e PCI DSS. No contexto do CompTIA Security+, a criptografia at-rest é classificada como um controle de proteção de dados em repouso, distinto da criptografia in-transit (em trânsito) e da criptografia in-use (em uso).

✗ **Por que as outras estão erradas:**

- *Durante a transmissão pela rede:* Esta alternativa descreve a criptografia in-transit (em trânsito), que protege dados enquanto trafegam por redes, utilizando protocolos como TLS, IPsec, SSH e HTTPS. O foco é evitar interceptação e adulteração durante a comunicação. No entanto, a pergunta refere-se especificamente à criptografia at-rest, que trata de dados armazenados, não de dados em movimento. Portanto, a alternativa está incorreta porque confunde o estado dos dados: transmissão versus repouso.
- *Em memória durante processamento:* Esta alternativa refere-se à criptografia in-use (em uso), que protege dados enquanto estão sendo processados na memória RAM ou em ambientes de execução confiável (TEEs), como Intel SGX ou AMD SEV. É um conceito emergente e voltado para cenários de computação confidencial. A criptografia at-rest não se aplica a dados em memória.

volátil, pois estes não estão armazenados de forma persistente. Logo, a alternativa está errada por descrever um estado diferente (em uso) e não o estado de repouso.

- *Em backups remotos*: Backups remotos são cópias de dados armazenadas em localidades distintas, geralmente para recuperação de desastres. Embora possam ser protegidos por criptografia at-rest, o termo 'backups remotos' não define o estado dos dados, mas sim a localização e a finalidade da cópia. A criptografia at-rest aplica-se a qualquer dado armazenado, incluindo backups, mas a alternativa é imprecisa porque restringe o conceito a um tipo específico de armazenamento, excluindo discos locais, bancos de dados e outros repositórios. Além disso, a pergunta pede onde os dados estão protegidos, e 'backups remotos' é um subconjunto, não a definição geral.

3) B — In-transit.

✓ **Por que está certa:** TLS (Transport Layer Security) e seu antecessor SSL (Secure Sockets Layer) são protocolos criptográficos que operam nas camadas de transporte e aplicação do modelo OSI/TCP-IP. Eles são projetados para proteger dados in-transit (em trânsito), ou seja, durante a transmissão pela rede. TLS/SSL fornecem confidencialidade (criptografia simétrica), integridade (HMAC) e autenticação (certificados digitais) para comunicações como HTTPS, FTPS, SMTPS, entre outras. No CompTIA Security+, TLS/SSL são exemplos clássicos de controles para proteger dados em movimento, mitigando ataques como eavesdropping, man-in-the-middle e tampering.

✗ Por que as outras estão erradas:

- *At-rest*: Criptografia at-rest protege dados armazenados em disco, banco de dados ou backups. TLS/SSL não atuam sobre dados em repouso, pois são protocolos de comunicação que só entram em ação durante a transmissão. A alternativa está errada porque confunde o estado dos dados: TLS/SSL não criptografam arquivos parados, mas sim o fluxo de dados entre sistemas.
- *Em uso*: Criptografia em uso (in-use) protege dados enquanto estão sendo processados na memória, utilizando técnicas como enclaves seguros (Intel SGX) ou criptografia homomórfica. TLS/SSL não operam nesse estado, pois não têm acesso à memória do processo, apenas ao canal de comunicação. A alternativa está incorreta porque descreve um estado de dados diferente daquele protegido por TLS/SSL.
- *Em backup*: Backups são cópias de dados armazenadas para recuperação. Embora possam ser protegidos por criptografia at-rest, TLS/SSL não são usados para criptografar backups em si, mas sim para proteger a transmissão dos dados de backup pela rede. A alternativa está errada porque restringe o escopo a backups, quando TLS/SSL protegem qualquer dado em trânsito, independentemente de ser backup ou não.

4) B — É de mão única (não reversível).

✓ **Por que está certa:** Uma característica fundamental das funções hash criptográficas é serem de mão única (one-way), ou seja, não reversíveis. Isso significa que, a partir do hash, não é possível recuperar a mensagem original. Essa propriedade é conhecida como resistência à pré-imagem. Diferentemente da criptografia, que é reversível com a chave correta, o hash é projetado para ser irreversível. O CompTIA Security+ destaca que funções hash como SHA-256 são usadas para integridade e armazenamento de senhas (com salt), justamente porque não podem ser revertidas. A opção 'É de mão única (não reversível)' descreve corretamente essa característica essencial.

✗ Por que as outras estão erradas:

- *Pode ser revertido com a chave*: Essa é uma característica da criptografia simétrica ou assimétrica, não de funções hash. Na criptografia, a reversão é possível com a chave apropriada (simétrica) ou com a chave privada (assimétrica). Funções hash não possuem chave e não são projetadas para reversão. Portanto, essa afirmação está incorreta para hash. O CompTIA Security+ enfatiza que hash é unidirecional e não usa chaves, ao contrário da cifra.

- *Sempre encurta o texto pela metade*: Funções hash produzem uma saída de tamanho fixo, independentemente do tamanho da entrada. Por exemplo, SHA-256 sempre gera 256 bits (32 bytes). Não há uma regra de 'encurtar pela metade'; o tamanho do digest é constante e definido pelo algoritmo. Além disso, a função hash não é uma compressão simples; ela deve ser resistente a colisões e pré-imagem. Essa afirmação é tecnicamente falsa e não descreve uma propriedade de hash.
- *Precisa de par de chaves*: Funções hash não utilizam chaves. Elas são algoritmos públicos e determinísticos que mapeiam dados de entrada para um resumo. O uso de par de chaves é característico de criptografia assimétrica (como RSA ou ECC), não de hash. Embora hashes possam ser usados em conjunto com chaves em HMAC, a função hash em si não requer chaves. Portanto, essa opção está incorreta.

5) D — Implementar a solução correspondente: At rest = disco; In transit = rede (TLS); In use = memória (mais difícil)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Encrypting Data): At rest = disco; In transit = rede (TLS); In use = memória (mais difícil).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) B — Implementar a solução correspondente: AES block cipher cifra em blocos de 128 bits....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Encrypting Data): AES block cipher cifra em blocos de 128 bits.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) D — Implementar a solução correspondente: Stream cipher: ChaCha20 — bom pra celular, sem hardware AES....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Encrypting Data): Stream cipher: ChaCha20 — bom pra celular, sem hardware AES.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) D — Implementar a solução correspondente: Na prova: 'data stored in the database' = at rest; 'during network transfer....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Encrypting Data): Na prova: 'data stored in the database' = at rest; 'during network transfer' = in transit.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) C — Implementar a solução correspondente: Pergunta de 'which provides protection for data in USE' = confidential comp....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Encrypting Data): Pergunta de 'which provides protection for data in USE' = confidential computing.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: Cenário: 'empresa precisa proteger o dado que está SENDO processado na memó....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Encrypting Data): Cenário: 'empresa precisa proteger o dado que está SENDO processado na memória' → confidential computing / enclaves (in use)..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.